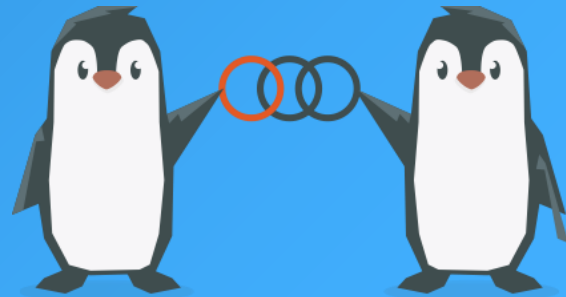


Status of OpenChain SBOM Document Quality Guide

2025-11-14

SBOM Working Group





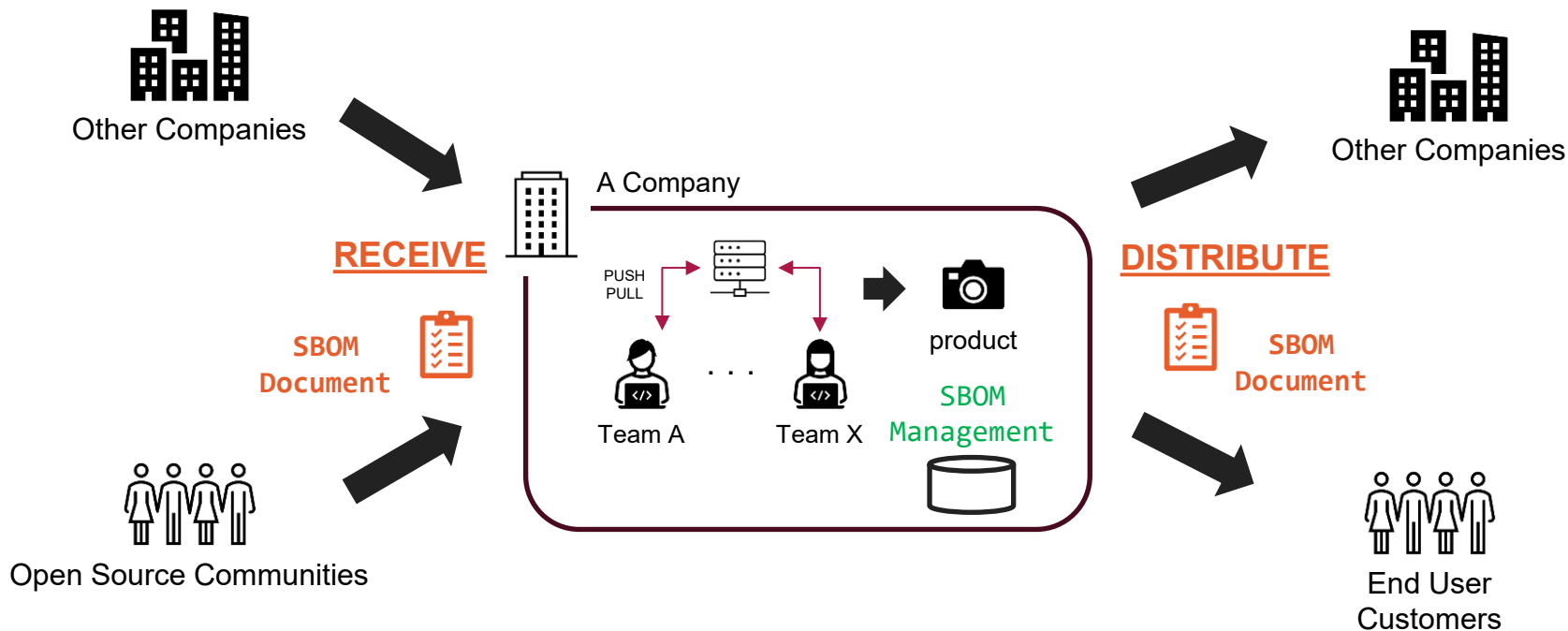
The OpenChain Project is set to release its new guidebook soon. This guidebook brings together **the collective insights and practical experiences of professionals working with SBOMs.**

As discussions continue and revisions are made, your expertise and feedback would be greatly appreciated.

SBOM Document Quality Guide

Compliance Management Guide for the Supply Chain

Scope and Definition



Guideline to Enhance SBOM Document Quality

3.2 SBOM Elements

An SBOM Document SHALL include all the SBOM Elements defined in this chapter, which the OpenChain SBOM Document Quality Guide considers indicative of high quality.

SBOM Document Information

- Data Format Version
- License for the SBOM Document
- Unique ID for the SBOM Document
Include a global unique identifier in the SBOM Document. The specification for this unique Data Format;
For example, CycloneDX has 'serialNumber', which must be global unique or a combination of 'Docu' used to ensure uniqueness.

Package information

- **Information that can uniquely identify a software package**
For accurate license compliance and vulnerability assessment, it is essential to correctly identify each software package. The document should include the following elements to ensure proper identification:
 - Package Name
 - Package Version
 - Details regarding the package identifiers, such as the [SoftWare Hash IDentifiers \(SWHID\)](#), the [package URL \(PURL\)](#), [CPE](#) or the URL of the package distribution site, indicating where the corresponding software package can be obtained.

Rather than emphasizing the literal values of names or versions, **it is crucial to provide information that uniquely identifies the software packages** in use or distribution.

Common SBOM Document Quality Issues and Improvement Measures

5.6 Clarifying the Scope of Descriptions and Defining Accountability

5.6.1 Issue Overview

SBOM documents largely rely on the provider's discretion, resulting in inconsistent comprehensiveness and accuracy of the required information. Consequently, essential data may be missing across the software supply chain, increasing the risk of confusion in managing security and license compliance.

5.6.2 Detailed Description

Various guidelines and specifications exist, yet the criteria for including dependent components in an SBOM and the level of detail required for each component remain unclear.

- Only a limited set of necessary details, such as the scope of software dependencies and version information, may be included.
- It is often unclear who is accountable for each component, as contact information and management responsibilities are not clearly defined. This lack of clarity hampers rapid response when issues arise.

Consequently, incomplete information within the SBOM can prevent a full understanding of vulnerabilities and license-related risks across the entire software supply chain, potentially impeding effective security measures.

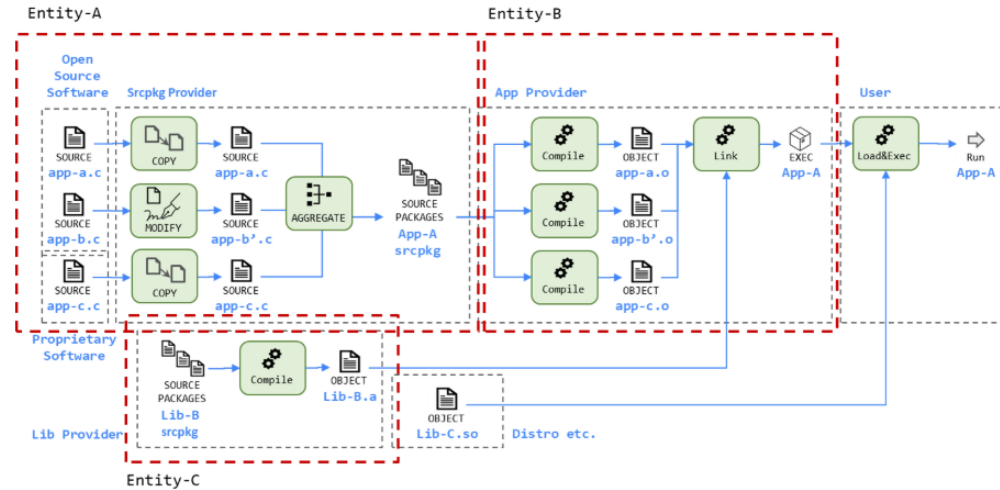


Fig.5-7.2 Three entities for "App-A SBOM Document" provided to "User".

"Entity-B" is generally responsible for direct vulnerability response and OSS license compliance for "User". There is no requirement to provide "User" with the contact details of "Entity-A" and "Entity-C"; however, "Entity-B" must know the proper contact information for "Entity-A" and "Entity-C". Consequently, the SBOM Document provided by "Entity-A" and "Entity-C" must include their respective appropriate contact details.

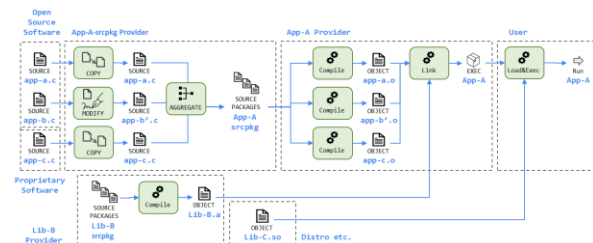
Compliance Elements in Relation to Legislation and Guidelines

6.1 NTIA - The Minimum Elements For a Software Bill of Materials (SBOM)

<https://www.ntia.gov/report/2021/minimum-elements-software-bill-materials-sbom>

6.1.1 Required Elements

Requirement Level	Element Name	SPDX v2.2+	SPDX v3.0	CycloneDX v1.6
SHALL	Supplier Name	(7.5) Package Supplier	Core/Classes/Artifact.suppliedBy	bom.metadata.supplier, bom.components[].supplier
SHALL	Component Name	(7.1) Package Name	Software/Classes/Package.name inherited from Core/Classes/Element.name	bom.components[].name
SHALL	Version of the Component	(7.3) Package Version	Software/Classes/Package.packageVersion	bom.components[].version



6.3 BSI TR-03183 Cyber Resilience Requirements for Manufacturers and Products Part 2: Software Bill of Materials (SBOM) Version 2.1.0

https://www.bsi.bund.de/EN/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/Technische-Richtlinien/TR-nach-Thema-sortiert/tr03183/TR-03183_node.html

6.3.1 Required Elements

TR-03182 version 2.1.0 does not allow SPDX v2.

Requirement Level	Element Name	SPDX v2.2+	SPDX v3.0	CycloneDX v1.6
SHALL	Creator of the SBOM	N/A	Core/Classes/CreationInfo.createdBy	bom.metadata.manufacturer[].url XOR bom.metadata.manufacturer[].contact[].email
SHALL	Timestamp	N/A	Core/Classes/CreationInfo.created	bom.metadata.timestamp
SHALL	Component creator	N/A	Software/Classes/Package.OriginatedBy	bom.components[].manufacturer[].url XOR bom.components[].manufacturer[].contact[].email

6.4 OpenChain Telco SBOM Guide Version 1.1

https://github.com/OpenChain-Project/Telco-WG/blob/main/OpenChain-Telco-SBOM-Guide_EN.md

6.4.1 Required Elements

Requirement Level	Element Name	SPDX v2.2+	SPDX v3.0	CycloneDX v1.6
	Document Creation Information			
SHALL	SPDXVersion: mandatory in SPDX	(6.1) SPDX Version	(Core/CreationInfo.specVersion)	(specVersion)
SHALL	DataLicense: mandatory in SPDX	(6.2) Data License	(Core/SpdxDocument.dataLicense)	(metadata.license s)
SHALL	SPDXID: mandatory in SPDX	(6.3) SPDX Identifier	(Core/SpdxDocument.spdxid)	(serialNumber)

Cover the required elements for various guidelines and provide specific SBOM Document in JSON files for a particular use case.

Thanks!

